



Levantamento de requisitos legais aplicáveis

Sistema de Gestão de Segurança da Informação

Interjato Telecom Ltda.

Realização: **APRIMOR Consultoria em Gestão
Organizacional Ltda.**

Índice de revisões

Rev.	Data	Revisões realizadas
0	29/05/2023	Emissão inicial
1	04/12/2023	Acrescentados os seguinte documentos: a) Obrigatórios : Lei Nº 9.296 de 24/07/1996; Lei Nº 12.846, de 01/08/2013; Resolução ANATEL Nº 738, de 21/12/2020, Resolução Anatel Nº 740, de 21/12/2020 e Emenda Constitucional nº 115, de 10/02/2022 b) Orientativos: ISO/IEC 20889:2018, NBR ISO 30301:2016, NBR ISO/IEC 27555:2023 Atualizadas Instruções técnicas relacionadas ao CBMRN
2	20/03/2025	Reaprovação do documento
3	02/04/2026	Reaprovação do documento

As informações contidas deste documento são de propriedade da Interjato Telecom Ltda., sendo proibida sua reprodução, divulgação e utilização sem autorização expressa da Diretora da organização.

Sumário

	página
A - Identificação da organização	04
B-Objetivo	04
C - Metodologia	04
D-Abrangência	04
E - Identificação das normas técnicas e legislação aplicáveis, por tema	05
Contextodaorganização	05
Partes interessadas	06
Processosdosistemadegestão	07
Liderança	07
Autoridades,responsabilidadesepapéisorganizacionais	07
Ações para abordar riscos e oportunidades	08
Tratamentodosriscos	09
Recursos e pessoas	10
Infraestrutura	10
Competência	12
Conscientização	12
Comunicação	12
Informaçãodocumentada	13
Gestão de mudanças	15
Projetoedeseenvolvimentodeprodutoseseserviços	15
Controle de produção e de provisão de serviço	15
Identificaçãoerastreabilidade	16
Propriedade pertencente a clientes ou provedores externos	16
Monitoramento,medição,análiseeavaliação	17
Auditoria interna	18
Incidente,nãoconformidadeeaçãoocorretiva	18
F - Lista simplificada das normas técnicas e legislação aplicáveis	20

A. Identificação da organização

Razão Social: Interjato Telecom Ltda.

CNPJ: 10.934.803/0001-77

CNAE Atividade Principal: 61.10-8-03 - Serviços de comunicação multimídia - SCM

B. Objetivo

Identificar os requisitos legais, incluindo normas técnicas, aplicáveis ao Sistema de Gestão de Segurança da Informação da organização como base para posterior avaliação do status de conformidade e realização de ações para suprir eventuais lacunas.

C. Metodologia

Este levantamento foi conduzido com base nas informações fornecidas pela organização, principalmente através de análise documental e entrevistas. A consultoria pesquisou as bases de normas técnicas e documentos legais para identificar as versões mais atualizadas na abrangência Nacional, Estadual (RN) e Municipal (Natal).

Os documentos identificados como "Orientativo" referem-se àqueles que podem auxiliar na implementação e/ou melhoria de uma determinada função no Sistema de Gestão, mas, no momento desta avaliação, não foram considerados obrigatórios. Nestes casos, caberá à organização decidir se irá considerá-los em seu Sistema de Gestão.

A aplicabilidade de alguns documentos normativos pode depender do contrato. Estes documentos estão sinalizados como "Aplicável, a depender do contrato"

Este estudo não incluiu a avaliação de atendimento aos quesitos aplicáveis de cada documento identificado.

D. Abrangência

Esse diagnóstico considerou as seguintes unidades/locais:

(L01) Sede

Rua Mirabeau da Cunha Melo, 1943, Candelaria, Natal - RN, 59064-490

E. Normas técnicas e legislação aplicáveis

Contexto da organização

Lei Nº 9.472, de 16/07/1997

Lei Geral de Telecomunicações - Estabelece as normas para o setor de telecomunicações no Brasil

Regula, em termos amplos, a atividade na área de telecomunicações

O Art. 3º dispõe que o usuário de serviços de telecomunicações tem direito à inviolabilidade e ao segredo de sua comunicação, salvo nas hipóteses e condições constitucionais e legalmente previstas;

O Art. 72 trata do uso de informações relativas à utilização individual do serviço pelo usuário.

Lei Nº 12.846, de 01/08/2013

Dispõe sobre a responsabilização administrativa e civil de pessoas jurídicas pela prática de atos contra a administração pública, nacional ou estrangeira, e dá outras providências.

O cumprimento desta lei é exigido nos contratos com entes da administração pública e por alguns clientes privados

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

A LGPD representa uma importante questão legal, associada à segurança da informação

Lei Nº 13.853, de 08/07/2019

Altera a Lei nº 13.709, de 14 de agosto de 2018, para dispor sobre a proteção de dados pessoais e para criar a Autoridade Nacional de Proteção de Dados; e dá outras providências.

A LGPD representa uma importante questão legal, associada à segurança da informação

Resolução ANATEL Nº 740, de 21/12/2020

Aprova o Regulamento de Segurança Cibernética Aplicada ao Setor de Telecomunicações.

Estabelece condutas e procedimentos para a promoção da segurança nas redes e serviços de telecomunicações, incluindo a Segurança Cibernética e a proteção das Infraestruturas Críticas de Telecomunicações.

Resolução ANATEL nº 746, de 22/06/2021

Aprova o Regulamento de Fiscalização Regulatória.

A organização deverá conhecer os critérios que estão envolvidos com o tema deste documento.

Resolução CD/ANPD Nº 1, de 28/10/2021

Aprova o Regulamento do Processo de Fiscalização e do Processo Administrativo Sancionador no âmbito da Autoridade Nacional de Proteção de Dados

A organização deverá conhecer as regras que estão envolvidas com o tema deste documento.

Resolução CD/ANPD Nº 4, de 24/02/2023

Aprova o Regulamento de Dosimetria e Aplicação de Sanções Administrativas

A organização deverá conhecer como se dá a aplicação de sanções administrativas pela Autoridade Nacional de Proteção de Dados (ANPD), bem como as formas e dosimetrias para o cálculo do valor-base das sanções de multa

ISO/IEC 17788, de 07/12/2015**Orientativo**

Tecnologia da informação - Computação em nuvem - Visão geral e vocabulário

Fornece uma visão geral de computação em nuvem, juntamente com um conjunto de termos e definições, as características-chave envolvidas, papéis principais, tipos de capacidades e categorias de serviço, modelos de implantação e aspectos transversais (comportamentos que precisam ser coordenados entre papéis e implantados consistentemente em um sistema de computação em nuvem).

Portaria GSI/PR Nº 93, de 18/10/2021**Orientativo**

Aprova o Glossário de Segurança da Informação

Trazo significado de termos associados à Segurança da Informação. Para conhecimento e uso, onde necessário, no sistema de gestão

Partes interessadas**Lei Nº 9.296, de 24/07/1996**

Regulamenta o inciso XII, parte final, do art. 5º da Constituição Federal (Lei de Interceptações).

Prevê os requisitos necessários à suspensão do sigilo, entre eles, haver indícios razoáveis, ser estritamente necessário o recurso à obtenção das provas e a imprescindibilidade de uma ordem judicial. A Lei dispõe, em seu Art. 1º, §1º, que a regulamentação também diz respeito “à interceptação do fluxo de comunicações em sistemas de informática e telemática.”

Portanto, a interceptação pode ser um requisito das seguintes partes interessadas: juiz, de ofício ou a requerimento da autoridade policial, na investigação criminal ou - do representante do Ministério Público, na investigação criminal e na instrução processual penal.

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

A ANPD é o órgão fiscalizador em questões relacionadas à proteção de dados pessoais e portanto, parte interessada.

A proteção à privacidade é um requisito de todos os titulares de dados pessoais

Lei Nº 13.853, de 08/07/2019

Altera a Lei nº 13.709, de 14 de agosto de 2018, para dispor sobre a proteção de dados pessoais e para criar a Autoridade Nacional de Proteção de Dados; e dá outras providências.

A ANPD é o órgão fiscalizador em questões relacionadas à proteção de dados pessoais e, portanto, parte interessada.

IN GSI Nº 05, de 30/08/2021

Dispõe sobre os requisitos mínimos de segurança da informação para utilização de soluções de computação em nuvem pelos órgãos e pelas entidades da administração pública federal.

Para os clientes que são órgãos e entidades da administração pública federal, trata dos requisitos que devem ser atendidos

O capítulo IV trata dos requisitos para a adoção segura de computação em nuvem

O capítulo V trata dos requisitos do provedor de serviço de nuvem

O capítulo VI trata da utilização de cloud brokers

Resolução CD/ANPD Nº 1, de 28/10/2021

Aprova o Regulamento do Processo de Fiscalização e do Processo Administrativo Sancionador no âmbito da Autoridade Nacional de Proteção de Dados

A organização deverá conhecer as regras que estão envolvidas com o tema deste documento, que passa a ser um dos requisitos da parte interessada ANPD

Emenda Constitucional nº 115, de 10/02/2022

Altera a Constituição Federal para incluir a proteção de dados pessoais entre os direitos e garantias fundamentais e para fixar a competência privativa da União para legislar sobre proteção e tratamento de dados pessoais.

Art. 1º O caput do art. 5º da Constituição Federal passa a vigorar acrescido do seguinte inciso LXXIX: "é assegurado, nos termos da lei, o direito à proteção dos dados pessoais, inclusive nos meios digitais."

Processos do Sistema de Gestão**NBR ISO/IEC 27003, de 24/04/2020****Orientativo**

Fornece orientações sobre os requisitos para um SGSI conforme especificado na NBR ISO/IEC 27001

Fornece orientações sobre os requisitos para um SGSI conforme especificado na NBR ISO/IEC 27001 e fornece recomendações ("Convém que"), possibilidades ("Pode") e permissões ("Pode") em relação a eles. As seções 4 a 10 espelham a estrutura da NBR ISO/IEC 27001, mas não adicionam quaisquer novos requisitos e seus termos e definições relacionados.

Liderança

NBR ISO/IEC 38505-1, de 20/01/2020

Orientativo

Tecnologia da Informação — Governança da TI - Parte 1: Aplicação da ABNT NBR ISO/IEC 38500 à governança de dados.

Fornecer princípios orientadores para os membros de estruturas de governança de organizações (que podem incluir proprietários, diretores, parceiros, gerentes executivos ou similares) sobre o uso eficaz, eficiente e aceitável de dados em suas organizações, por meio de: aplicação dos princípios e modelo de governança da ABNT NBR ISO/IEC 38500 à governança de dados, asseguramento às partes interessadas de que, se os princípios e práticas propostas por este documento forem seguidos, eles podem confiar na governança de dados da organização, informação e orientação às estruturas de governança sobre o uso e proteção de dados em sua organização, e estabelecimento de um vocabulário para a governança de dados.

NBR ISO/IEC 38505-2, de 12/07/2022

Orientativo

Tecnologia da informação - Governança de TI - Governança de dados - Parte 2: Implicações da ABNT NBR ISO/IEC 38505-1 para gerenciamento de dados

Descreve o que o corpo diretivo de uma organização espera e requer da equipe de gerenciamento de dados, a fim de assegurar que os princípios de governança de TI possam ser implementados e estão sendo mantidos para os dados e seu uso pela organização.

Autoridades, responsabilidades e papéis organizacionais

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

Os Artigos 37 a 40 e 42 tratam das responsabilidades do Controlador e do Operador. O Artigo 41 trata das responsabilidades do DPO (Encarregado pelo Tratamento de Dados Pessoais)

Ações para abordar riscos e oportunidades

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

Art. 5º: XVII- relatório de impacto à proteção de dados pessoais: documentação do controlador que contém a descrição dos processos de tratamento de dados pessoais que podem gerar riscos às liberdades civis e aos direitos fundamentais, bem como medidas, salvaguardas e mecanismos de mitigação de risco;

Art. 38. A autoridade nacional poderá determinar ao controlador que elabore relatório de impacto à proteção de dados pessoais, inclusive de dados sensíveis, referente a suas operações de tratamento de dados, nos termos de regulamento, observados os segredos comercial e industrial. Parágrafo único. Observado o disposto no caput deste artigo, o relatório deverá conter, no mínimo, a descrição dos tipos de dados coletados, a metodologia utilizada para a coleta e para a garantia da segurança das informações e a análise do controlador com relação a medidas, salvaguardas e mecanismos de mitigação de risco adotados.

No Capítulo VII, que trata da segurança e das práticas, as duas primeiras seções abordam a necessidade de mecanismos internos de supervisão e mitigação de riscos. Art. 49: Os sistemas utilizados para o tratamento de dados pessoais devem ser estruturados de forma a atender aos requisitos de segurança, aos padrões de boas práticas e de governança e aos princípios gerais previstos nesta Lei e às demais normas regulamentares; Art. 50: Os controladores e operadores, no âmbito de suas competências, pelo tratamento de dados pessoais, individualmente ou por meio de associações, poderão formular regras de boas práticas e de governança que estabeleçam os mecanismos internos de supervisão e de mitigação de risco e outros aspectos relacionados ao tratamento de dados pessoais.

NBR 11515, de 10/12/2007

Orientativo

Guia de práticas para segurança física relativas ao armazenamento de dados

O item 4.1 traz ameaças a serem consideradas para os ambientes onde as informações são geradas e armazenadas para fins operacionais e do local onde são guardadas as cópias de segurança (Back up)

NBR ISO 31000, de 28/03/2018

Orientativo

Gestão de Riscos - Diretrizes

Fornece diretrizes para gerenciar riscos enfrentados pelas organizações e suas diretrizes podem ser personalizadas para qualquer organização e seu contexto. Fornece uma abordagem comum para gerenciar qualquer tipo de risco e não é específico para qualquer indústria ou setor.

NBR ISO/IEC 27005, de 24/10/2019

Orientativo

Tecnologia da informação — Técnicas de segurança — Gestão de riscos de segurança da informação

Fornece diretrizes para a gestão de riscos de segurança da informação em uma organização. A Tabela Anexo C desta norma contém exemplos de ameaças comuns e pode ser usada durante o processo de avaliação das ameaças.

NBR ISO/IEC 29134, de 26/11/2020**Orientativo**

Tecnologia da informação - Técnicas de segurança - Avaliação de impacto de privacidade - Diretrizes

Além da sistemática de Avaliação de Impacto de Privacidade, a norma traz uma listagem (Anexo B) de ameaças típicas envolvendo os dados pessoais

NBR ISO/IEC 27035-3, de 15/07/2021**Orientativo**

Tecnologia da informação - Gestão de incidentes de segurança da informação - Parte 3: Diretrizes para operações de resposta a incidentes de TIC

O Anexo A traz exemplos de parâmetros para classificação de incidentes e respectivos impactos. Pode ser utilizada como diretriz geral para as análises de riscos

NBR ISO 31073, de 14/07/2022**Orientativo**

Gestão de riscos — Vocabulário

Fornece o vocabulário básico para desenvolver um entendimento comum sobre termos e conceitos de gestão de riscos entre organizações e funções, e através de diferentes aplicações e tipos

Tratamento dos riscos**Lei Nº 13.709, de 14/08/2018**

Lei Geral de Proteção de Dados Pessoais (LGPD).

Ver artigos 38, 49 e 50

Lei Nº 13.853, de 08/07/2019

Altera a Lei nº 13.709, de 14 de agosto de 2018, para dispor sobre a proteção de dados pessoais e para criar a Autoridade Nacional de Proteção de Dados; e dá outras providências.

Ver Lei Nº 13.709

NBR ISO 31000, de 28/03/2018**Orientativo**

Gestão de Riscos - Diretrizes

Toda a norma é aplicável como orientação sobre a gestão de riscos

NBR ISO/IEC 27005, de 24/10/2019**Orientativo**

Tecnologia da informação — Técnicas de segurança — Gestão de riscos de segurança da informação

A seção 9 da norma aborda o Tratamento dos riscos de segurança da informação

Recursos e pessoas

Decreto-Lei Nº 5.452, de 01/05/1943

Aprova a Consolidação das Leis do Trabalho.

Os artigos 75-A a 75-F (Incluídos pela Lei nº 13.467, de 2017 pela Lei nº 14.442, de 2022) definem o teletrabalho ou trabalho remoto e as regras aplicáveis, entre as quais: Art. 75-C. Prestação de serviços na modalidade de teletrabalho deverá constar expressamente do instrumento de contrato individual de trabalho -

NBR ISO/IEC 27005, de 24/10/2019

Orientativo

Tecnologia da informação — Técnicas de segurança — Gestão de riscos de segurança da informação

O Anexo B desta norma traz orientações interessantes para a gestão dos recursos, no caso, dos ativos de informação: B.1 Exemplos de identificação de ativos, B.2 Valoração dos Ativos.

Infraestrutura

Instrução Técnica CBMRN Nº 16, de 2022

Gerenciamento de riscos de incêndio

Entre os objetivos desta IT estão: Estabelecer os requisitos mínimos para a elaboração, manutenção e revisão de um plano de emergência contra incêndio, acidentes e demais emergências e fornecer informações operacionais das edificações ou áreas de risco, padronizando, fornecendo e alocando plantas de riscos nas edificações para otimizar o atendimento operacional prestado pelo Corpo de Bombeiros.

Esta Instrução Técnica (IT) aplica-se às edificações e áreas de risco onde se exige o Gerenciamento de Riscos, de acordo com o Regulamento de segurança contra incêndio das edificações e áreas de risco do Estado do Rio Grande do Norte.

5.3.2 Política de Gerenciamento de riscos de Incêndio

5.4.2 Identificação dos riscos

5.4.3 Análise de riscos

5.4.4 Tratamento de riscos

5.5 Responsabilidade pelo Gerenciamento de Riscos de Incêndio, Acidentes e demais emergências

6.2 Elaboração do Plano de emergência (O Anexo B apresenta um modelo de Plano de Emergência)

6.3 Planilha de informações operacionais (As informações operacionais devem ser fornecidas por meio do preenchimento de planilha, constante no "Anexo D")

6.4 Planta de risco de incêndio

6.5 Divulgação e treinamento do plano de emergência.

6.6 Exercícios simulados

6.7 Manutenção do Plano de emergência

6.8 Revisão do Plano de emergência

Instrução Técnica CBMRN Nº 21, de 2022

Sistema de proteção por extintores de incêndio

Estabelece critérios para proteção contra incêndio em edificações e áreas de risco por meio de extintores de incêndio (portáteis ou sobre rodas), para o combate a princípios de incêndios

5.1 Capacidade extintora

5.2 Instalação e sinalização

5.3 Certificação, validade e garantia

NBR 5419-1, de 22/05/2015

Proteção contra descargas atmosféricas - Parte 1: Princípios gerais

Esta Parte da ABNT NBR 5419 estabelece os requisitos para a determinação de proteção contra descargas atmosféricas e fornece subsídios para o uso em projetos de proteção contra descargas atmosféricas.

NBR 5419-2, de 22/05/2015

Proteção contra descargas atmosféricas - Parte 2: Gerenciamento de risco

Esta Parte da ABNT NBR 5419 estabelece os requisitos para análise de risco em uma estrutura devido às descargas atmosféricas para a terra e tem o propósito de fornecer um procedimento para a avaliação de tais riscos. Uma vez que um limite superior tolerável para o risco foi escolhido, este procedimento permite a escolha das medidas de proteção apropriadas a serem adotadas para reduzir o risco ao limite ou abaixo do limite tolerável.

NBR 5419-4, de 22/05/2015

Proteção contra descargas atmosféricas - Parte 4: Sistemas elétricos e eletrônicos internos na estrutura

Esta Parte da ABNT NBR 5419 fornece informações para o projeto, instalação, inspeção, manutenção e ensaio de sistemas de proteção elétricos e eletrônicos (Medidas de Proteção contra Surtos—MPS) para reduzir o risco de danos permanentes internos à estrutura devido aos impulsos eletromagnéticos de descargas atmosféricas (LEMP). Entretanto, não cobre a proteção total contra interferências eletromagnéticas devido às descargas atmosféricas, que podem causar mau funcionamento de sistemas internos.

Lei Complementar (RN) Nº 601, de 07/08/2017

Institui o Código Estadual de Segurança Contra Incêndio e Pânico (CESIP) do Estado do Rio Grande do Norte

O Código Estadual de Segurança Contra Incêndio e Pânico do Rio Grande do Norte (CESIP), que tem por finalidade prevenir e promover medidas de segurança contra incêndio e pânico nas edificações, áreas de risco e estruturas provisórias

A Seção I trata do Certificado de Licenciamento do Corpo de Bombeiros (CLCB) para as edificações e áreas de baixo risco receberão tratamento diferenciado e simplificado, observada a atividade econômica exercida, associada ou não a outros critérios de controle sanitário, controle ambiental e segurança contra incêndio.

Seção II Auto de Vistoria do Corpo de Bombeiros (AVCB) e Auto de Vistoria de Medidas Compensatórias do Corpo de Bombeiros (AVCBMC) para as edificações e áreas de risco classificadas como de alto risco.

O Capítulo II traz as exigências técnicas e medidas de segurança contra incêndio e pânico

Art. 25. A renovação do AVCB do AVCBMC deverá ser requerida com antecedência mínima de 90 (noventa) dias da expiração de seu prazo de validade

Art. 27. O prazo de validade do AVCB e do AVCBMC será de um ano

NBR 15219, de 16/04/2020

Plano de emergência contra incêndio - Requisitos e procedimentos

Esta Norma especifica os requisitos e procedimentos para a elaboração, implantação e manutenção de um plano de emergência contra incêndio,

Competência**NBR ISO 10015, de 01/07/2020****Orientativo**

Gestão da qualidade – Diretrizes para gestão da competência e desenvolvimento de pessoas

Provê orientação para auxiliar organizações e seu pessoal a abordarem questões relacionadas à gestão de competência e ao desenvolvimento de pessoas. O item 4.2 traz as orientações para determinação das necessidades de competência, o item 4.3 aborda a avaliação das necessidades atuais de competência e desenvolvimento e a seção 5 trata da operacionalização, envolvendo planejamento, programa e ações

Conscientização**NBR ISO 10018, de 09/02/2022****Orientativo**

Gestão da qualidade - orientação para o engajamento de pessoas

Esta norma provê orientação sobre como mudanças importantes podem ser feitas no nível do engajamento de pessoas com a qualidade em organizações de todos os tipos e portes para o benefício de todas as partes interessadas.

Apesar de o foco na qualidade, as orientações podem ser adaptadas a outros sistemas de gestão

Comunicação**Lei Nº 12.965, de 23/04/2014**

Marco Civil da Internet. Estabelece princípios, garantias, direitos e deveres para o uso da internet no Brasil

A Seção II trata da Proteção aos Registros, aos Dados Pessoais e às Comunicações Privadas

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

A LGPD exige algumas instâncias de comunicação, sob responsabilidade do encarregado, entre as quais: Art. 7º: O tratamento de dados pessoais somente poderá ser realizado mediante o fornecimento de consentimento pelo titular; Art. 41: O encarregado deverá: I - aceitar reclamações e comunicações dos titulares, prestar esclarecimentos e adotar providências; II - receber comunicações da autoridade nacional e adotar providências; Art. 48: O controlador deverá comunicar à autoridade nacional a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares.

NBR ISO/IEC 29184, de 25/06/2021**Orientativo**

Tecnologia da informação - Avisos de privacidade on-line e consentimento

A norma especifica controles e informações adicionais associadas para organizações fornecerem a base para a apresentação de informações claras e de fácil compreensão para indivíduos cujos DP são coletados, sobre como a organização trata seus DP (por exemplo, ao fornecer serviços a consumidores ou em uma relação de trabalho); obterem o consentimento dos titulares de DP de maneira justa, demonstrável, transparente, inequívoca e revogável (retirável). É aplicável a qualquer contexto on-

IN GSI Nº 06, de 23/12/2021**Orientativo**

Estabelece diretrizes de segurança da informação para o uso seguro de mídias sociais nos órgãos e nas entidades da administração pública federal.

Embora seja direcionada para órgãos e entidades da administração pública federal, pode ser utilizada como referência para a adoção de padrões similares por outras organizações.

O Capítulo IV trata das diretrizes de segurança da informação para o uso institucional de mídias sociais

Informação documentada**Lei Nº 12.682, de 09/07/2012**

Dispõe sobre a elaboração e o arquivamento de documentos em meios eletromagnéticos.

Art. 2º-A. Fica autorizado o armazenamento, em meio eletrônico, óptico ou equivalente, de documentos públicos ou privados, compostos por dados ou por imagens, observado o disposto nesta Lei, nas legislações específicas e no regulamento.

Art. 2º-A § 1º Após a digitalização, constatada a integridade do documento digital nos termos estabelecidos no regulamento, o original poderá ser destruído, ressalvados os documentos de valor histórico, cuja preservação observará o disposto na legislação específica

Art. 2º-A § 2º O documento digital e a sua reprodução, em qualquer meio, realizada de acordo com o disposto nesta Lei e na legislação específica, terão o mesmo valor probatório do documento original, para todos os fins de direito, inclusive para atender ao poder fiscalizatório do Estado.

Art. 4º As empresas privadas ou os órgãos da Administração Pública direta ou indireta que utilizarem procedimentos de armazenamento de documentos em meio eletrônico, óptico ou equivalente deverão adotar sistema de indexação que possibilite a sua precisa localização, permitindo a posterior conferência da regularidade das etapas do processo adotado

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

A proteção da informação documentada que traz dados pessoais deve seguir as determinações desta lei.

Lei Nº 13.853, de 08/07/2019

Altera a Lei nº 13.709, de 14 de agosto de 2018, para dispor sobre a proteção de dados pessoais e para criar a Autoridade Nacional de Proteção de Dados; e dá outras providências.

VerLeiNº13.709

Lei Nº 13.874, de 20/09/2019

Institui a Declaração de Direitos de Liberdade Econômica

Art. 3º São direitos de toda pessoa, natural ou jurídica, essenciais para o desenvolvimento e o crescimento econômicos do País, X - arquivar qualquer documento por meio de microfilme ou por meio digital, conforme técnica e requisitos estabelecidos em regulamento, hipótese em que se equiparará a documento físico para todos os efeitos legais e para a comprovação de qualquer ato de direito público

Decreto Nº 10.278, de 18/03/2020

Regulamenta o disposto no inciso X do caput do art. 3º da Lei nº 13.874, de 20 de setembro de 2019, e no art. 2º-A da Lei nº 12.682, de 9 de julho de 2012.

Estabelece a técnica e os requisitos para a digitalização de documentos públicos ou privados, a fim de que os documentos digitalizados produzam os mesmos efeitos legais dos documentos originais.

Lei Nº 14.063, de 23/09/2020

Dispõe sobre o uso de assinaturas eletrônicas em interações com entes públicos, em atos de pessoas jurídicas e em questões de saúde e sobre as licenças de softwares desenvolvidos por entes públicos

O Art. 2º esclarece a aplicabilidade desta lei, incluindo: " interação entre pessoas naturais ou pessoas jurídicas de direito privado e os entes públicos". A lei não se aplica à "interação entre pessoas naturais ou entre pessoas jurídicas de direito privado"

A Seção II aborda a classificação das assinaturas eletrônicas

A Seção III trata da aceitação e da utilização de assinaturas eletrônicas pelos entes públicos

Resolução ANATEL Nº 738, de 21/12/2020

Altera o Regulamento dos Serviços de Telecomunicações para incluir disposições sobre sigilo, prevenção à fraude e ações de apoio à segurança pública, e dá outras providências.

Art. 65-J. A fim de assegurar a permanente fiscalização e o acompanhamento de obrigações legais e regulatórias, as prestadoras devem manter à disposição da Anatel os dados relativos à prestação do serviço, incluindo, conforme o caso e observada a regulamentação pertinente: II - registros de conexão à Internet pelo prazo mínimo de 1 (um) ano nos serviços que permitam a conexão à Internet.

Parágrafo único do Art. 65-J: considera-se registro de conexão à Internet o conjunto de informações referentes à data e hora de início e término de uma conexão à Internet, sua duração e o endereço IP utilizado pelo terminal, assim como as portas lógicas utilizadas quando do compartilhamento de IP público, para o envio e recebimento de pacotes de dados.

NBR 11515, de 10/12/2007**Orientativo**

Guia de práticas para segurança física relativas ao armazenamento de dados

Estabelece condições ambientais exigíveis para o armazenamento de dados em condições operacionais ou cópias de segurança (Back up), transporte, bem como em situação de emergência. Aplica-se a todos os usuários e gestores dos ativos de informações e abrange meios de armazenamento eletrônicos, magnéticos e microfilmagem

NBR ISO/IEC 27032, de 09/06/2015**Orientativo**

Tecnologia da Informação - Técnicas de segurança - Diretrizes para segurança cibernética

A primeira área de foco desta Norma é a segurança do espaço cibernético ou as questões de segurança cibernética que se concentram em preencher as lacunas nos diferentes domínios de segurança do Espaço Cibernético. Em particular, esta Norma oferece diretriz técnica para tratar os riscos de Segurança Cibernética comuns. A segunda área de foco desta Norma é a colaboração, assim como uma necessidade de compartilhamento de informações eficiente e eficaz, para coordenação e gestão de incidentes entre as partes interessadas (stakeholders) no Espaço Cibernético.

NBR ISO 30301, de 26/10/2016**Orientativo**

Informação e documentação - Sistemas de gestão de documentos de arquivo - requisitos

Esta Norma especifica os requisitos para serem seguidos por um SGDA com a finalidade de apoiar uma organização no cumprimento de suas obrigações, missão, estratégias e objetivos. Especifica o desenvolvimento e implementação de uma política de documentos de arquivo e seus objetivos, e fornece informações de mensuração e monitoramento de desempenho.

O Anexo A apresenta os processos e controle de documentos de arquivo que devem ser implementados por uma organização que deseja a conformidade com esta norma, envolvendo, por exemplo: Determinação de quais documentos de arquivo, quando e como devem ser produzidos e capturados em cada processo de negócio, determinação de quais metadados devem ser produzidos por meio de processos de documentos de arquivo e como estes devem estar vinculados aos documentos de arquivo e gerenciados ao longo do tempo

NBR 16167, de 18/12/2020**Orientativo**

Segurança da informação - Diretrizes para classificação, rotulação, tratamento e gestão da informação

Estabelece as diretrizes para classificação, rotulação, tratamento e gestão da informação, de acordo com a sua sensibilidade e criticidade para a organização, visando o estabelecimento de níveis adequados de proteção.

A tabela 1, no item 7, traz uma referência básica para o estabelecimento dos níveis de classificação (04 níveis)

NBR ISO/IEC 27555, de 16/02/2023**Orientativo**

Segurança da informação, segurança cibernética e proteção da privacidade — Diretrizes sobre remoção de dados pessoais

Este documento contém diretrizes para o desenvolvimento e estabelecimento de políticas e procedimentos para remoção de dados pessoais (DP) nas organizações, especificando: uma terminologia harmonizada para remoção de DP; uma abordagem para estabelecer regras de remoção de forma eficiente; uma descrição da documentação requerida; uma determinação ampla de papéis, responsabilidades e processos.

Gestão de mudanças**NBR ISO/IEC 29134, de 26/11/2020****Orientativo**

Tecnologia da informação - Técnicas de segurança - Avaliação de impacto de privacidade - Diretrizes

A Avaliação de impacto de privacidade deve ser considerada em mudanças que afetem os dados pessoais (privacidade). Ver, principalmente, os Anexos A.2 (Nível de impacto) e C.4 (Significado)

Projeto e desenvolvimento de produtos e serviços**NBR 16337, de 15/04/2020****Orientativo**

Gerenciamento de riscos em projetos — Princípios e diretrizes gerais

Descreve conceitos e processos que são considerados boas práticas em gerenciamento de risco em projetos.

Pode ser utilizada para qualquer tipo de projeto, independentemente da complexidade, tamanho e duração.

Controle de produção e de provisão de serviço**Lei Nº 13.709, de 14/08/2018**

Lei Geral de Proteção de Dados Pessoais (LGPD).

Na prestação de serviços que lidam com dados pessoais dos clientes, os requisitos desta lei devem ser obedecidos

Identificação e rastreabilidade

Lei Nº 12.965, de 23/04/2014

Marco Civil da Internet. Estabelece princípios, garantias, direitos e deveres para o uso da internet no Brasil

Art. 13. Na provisão de conexão à internet, cabe ao administrador de sistema autônomo respectivo o dever de manter os registros de conexão, sob sigilo, em ambiente controlado e de segurança, pelo prazo de 1 (um) ano, nos termos do regulamento.

Art. 15. O provedor de aplicações de internet constituído na forma de pessoa jurídica e que exerça essa atividade de forma organizada, profissionalmente e com fins econômicos deverá manter os respectivos registros de acesso a aplicações de internet, sob sigilo, em ambiente controlado e de segurança, pelo prazo de 6 (seis) meses, nos termos do regulamento.

Propriedade pertencente a clientes ou provedores externos

Lei Nº 8.078, de 11/09/1990

Código de Defesa do Consumidor

A seção VI trata dos Bancos de Dados e Cadastros de Consumidores

Os Arts. 72 e 73 tratam de infrações penais relacionadas aos cadastros, banco de dados, fichas e registros dos consumidores

Lei Nº 9.609, de 19/02/1998

Dispõe sobre a proteção da propriedade intelectual de programa de computador, sua comercialização no País, e dá outras providências.

Art. 2º O regime de proteção à propriedade intelectual de programa de computador é o conferido às obras literárias pela legislação de direitos autorais e conexos vigentes no País, observado o disposto nesta Lei.

O Art. 6º define o que não constitui ofensa aos direitos do titular de programa de computador

Art. 9º O uso de programa de computador no País será objeto de contrato de licença.

O Capítulo VI trata das infrações e das penalidades

Lei Nº 9.610, de 19/02/1998

Altera, atualiza e consolida a legislação sobre direitos autorais e dá outras providências.

Aplicável aos casos de uso de documentos, marcas, imagens ou outros direitos autorais de terceiros

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

Dados pessoais (ou seja, informação relacionada a pessoa natural identificada ou identificável) coletados pela empresa permanecem propriedade de seus titulares e devem ser protegidos nos termos desta lei

Lei Nº 13.853, de 08/07/2019

Altera a Lei nº 13.709, de 14 de agosto de 2018, para dispor sobre a proteção de dados pessoais e para criar a Autoridade Nacional de Proteção de Dados; e dá outras providências.

VerLeiNº13.709

Resolução ANATEL Nº 738, de 21/12/2020

Altera o Regulamento dos Serviços de Telecomunicações para incluir disposições sobre sigilo, prevenção à fraude e ações de apoio à segurança pública, e dá outras providências.

Art. 65-H. As prestadoras devem zelar pelo sigilo das comunicações e pela confidencialidade dos dados dos usuários de seus serviços, inclusive registros de conexão, nos termos da legislação e regulamentação.

Art. 65-I. As prestadoras devem reter a menor quantidade possível de dados de usuários, mantendo-os sob sigilo, em ambiente controlado e de segurança, excluindo-os tão logo atingida a finalidade de seu tratamento ou quando encerrado o prazo de guarda determinado por obrigação legal ou regulatória.

ISO/IEC 20889, de 2018**Orientativo**

Privacy enhancing data deidentification terminology and classification of techniques

Aborda o tema da desidentificação de dados, fornecendo uma visão geral dos conceitos centrais e estabelecendo uma terminologia padrão para as técnicas de desidentificação. Além disso, trata das técnicas comumente utilizadas para a desidentificação de conjuntos de dados estruturados, bem como em conjuntos de dados que contêm informações sobre dados principais que podem ser representados logicamente na forma de uma tabela.

NBR ISO/IEC 29100, de 27/03/2020**Orientativo**

Tecnologia da informação — Técnicas de segurança — Estrutura de Privacidade

Fornecer uma estrutura de alto nível para a proteção de dados pessoais (DP) dentro de sistemas de tecnologia da informação e de comunicação (TIC). Ela é geral em sua natureza e coloca os aspectos organizacionais, técnicos e processuais em uma estrutura abrangente de privacidade.

Na avaliação da aplicação dos dados pessoais, a tabela 2 traz exemplos de atributos que podem ser usados para identificar pessoas naturais

O item 4.6 trata de políticas de privacidade

A tabela 3 (item 5.1) traz os princípios de privacidade da NBR ISO/IEC 29100, que são desdobrados do item 5.2 até o item 5.11

NBR ISO/IEC 29151, de 26/11/2020**Orientativo**

Tecnologia da informação - Técnicas de segurança - Código de prática para proteção de dados pessoais

Este documento se baseia na NBR ISO/IEC 27002, adicionando novos controles específicos para a proteção de dados pessoais. Muitos dos controles da NBR ISO/IEC 27002 não precisam de extensão no contexto dos controladores de DP. No entanto, em alguns casos, são necessárias diretrizes adicionais de implementação, que são fornecidas.

Oferece orientações aos controladores de DP em uma ampla variedade de controles de segurança da informação e proteção de DP que são comumente aplicados em diferentes organizações.

O anexo normativo contém um conjunto estendido de controles específicos de proteção de DP que suplementam os dados da NBR ISO/IEC 27002, divididos em 12 categorias, correspondentes à política de privacidade e aos 11 princípios de privacidade da NBR ISO/IEC 29100.

Monitoramento, medição, análise e avaliação**NBR ISO/IEC 27004, de 29/08/2017****Orientativo**

Tecnologia da informação — Técnicas de segurança — Sistemas de gestão da segurança da informação — Monitoramento, medição, análise e avaliação

Tem como objetivo auxiliar as organizações a avaliar o desempenho da segurança da informação e a eficácia do SGSI, a fim de atender aos requisitos da NBR ISO/IEC 27001, 9.1

A tabela do Anexo B traz 37 exemplos de modelos de medição com as seções específicas ou números de controles da ABNT NBR ISO/IEC 27001

Auditoria interna**NBR ISO 19011, de 20/12/2018****Orientativo**

Diretrizes para auditoria de sistemas de gestão

Fornece orientação para todos os tamanhos e tipos de organizações e auditorias de variados escopos e dimensões. Esta norma concentra-se em auditorias internas (primeira parte) e auditorias conduzidas por organizações em seus fornecedores externos e outras partes interessadas externas (segunda parte).

NBR ISO/IEC 27007, de 11/05/2021**Orientativo**

Segurança da informação, segurança cibernética e proteção da privacidade - Diretrizes para auditoria de sistemas de gestão da segurança da informação

Fornece orientações sobre como gerenciar um programa de auditoria de sistemas de gestão da segurança da informação (SGSI), como executar as auditorias e a competência dos auditores de SGSI, em complemento às orientações descritas na ABNT NBR ISO 19011

O Anexo A fornece orientações genéricas de como auditar um SGSI, para a qual uma organização reivindica conformidade com a ABNT NBR ISO/IEC 27001

A Tabela A.2 – Diretrizes de auditoria para ABNT NBR ISO/IEC 27001 detalha as diretrizes de auditoria com informações sobre: o número e o nome da subseção correspondente da NBR ISO/IEC 27001; Subseções relacionadas da ABNT NBR ISO/IEC 27001; Definições pertinentes da ISO/IEC 27000; Evidência de auditoria; Diretriz prática da auditoria e Documentos de apoio

Incidente, não conformidade e ação corretiva**Decreto-Lei Nº 5.452, de 01/05/1943**

Aprova a Consolidação das Leis do Trabalho.

O Art. 482 define o que constitui justa causa para rescisão do contrato de trabalho pelo empregador.

Uma das hipóteses para justa causa é a violação de segredo da empresa, o que tem relação direta com a Segurança de informações e deve ser observado que a demissão por justa causa não depende necessariamente de uma punição progressiva e agravidade do ato cometido pelo funcionário poder ser um fator decisivo neste caso.

Outra possibilidade é a desídia (comportamento negligente, usado para representar a atitude de um funcionário que executa suas funções com desleixo, preguiça, desatenção ou má vontade). A desídia não é considerada grave, isoladamente, mas sua repetição pode torna o vínculo justificadamente insustentável.

Lei Nº 13.709, de 14/08/2018

Lei Geral de Proteção de Dados Pessoais (LGPD).

Art. 48. O controlador deverá comunicar à autoridade nacional e ao titular a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares.

Ver: https://www.gov.br/anpd/pt-br/canais_atendimento/agente-de-tratamento/comunicado-de-incidente-de-seguranca-cis

Resolução ANATEL Nº 740, de 21/12/2020

Aprova o Regulamento de Segurança Cibernética Aplicada ao Setor de Telecomunicações.

O Art. 17 exige que a prestadora realize junto à Anatel, a notificação dos incidentes relevantes que afetem de maneira substancial a segurança das redes de telecomunicações e dos dados dos usuários, além disso, menciona que a notificação do incidente relevante deve incluir análise da causa e do impacto, bem como ações de mitigação adotadas, conforme o caso.

Lei Nº 12.737, de 30/11/2012**Orientativo**

Dispõe sobre a tipificação criminal de delitos informáticos; altera o Decreto-Lei nº 2.848, de 7 de dezembro de 1940 - Código Penal; e dá outras providências.

A invasão de dispositivo informático alheio, conectado ou não à rede de computadores, mediante violação indevida de mecanismo de segurança e com o fim de obter, adulterar ou destruir dados ou informações sem autorização expressa ou tácita do titular do dispositivo ou instalar vulnerabilidades para obter vantagem ilícita é crime.

NBR ISO/IEC 27037, de 09/12/2013**Orientativo**

Tecnologia da informação — Técnicas de segurança — Diretrizes para identificação, coleta, aquisição e preservação de evidência digital

Fornece diretrizes para atividades específicas no tratamento de potenciais evidências digitais (identificação, coleta, aquisição e preservação de potenciais evidências digitais). Esses processos são necessários em uma investigação designada para preservar a integridade da evidência digital—uma metodologia aceitável na obtenção de evidência digital que contribuirá para a sua admissibilidade em processos judiciais e disciplinares, bem como em outras instâncias necessárias. Esta Norma também fornece diretrizes gerais para a coleta de evidência não digital capaz de auxiliar no estágio de análise da potencial evidência digital.

NBR ISO/IEC 27035-3, de 15/07/2021**Orientativo**

Tecnologia da informação - Gestão de incidentes de segurança da informação - Parte 3: Diretrizes para operações de resposta a incidentes de TIC

Este documento fornece diretrizes para resposta a incidentes de segurança da informação em operações de TIC. Este documento faz isso abrangendo, em primeiro lugar, os aspectos operacionais da segurança de TIC em uma perspectiva de pessoas, processos e tecnologia. Em seguida, concentra-se ainda mais na resposta de incidente de segurança da informação em operações de TIC, incluindo detecção de incidentes de segurança da informação, relatórios, triagem, análise, resposta, contenção, erradicação, recuperação e conclusão. Este documento não trata de operações de resposta a incidentes que não sejam de TIC, como perda de documentos em papel.

F. Lista das normas técnicas e legislação aplicáveis

56 documentos identificados, sendo:

28 documentos de cumprimento obrigatório:

28 documentos de caráter orientativo:

0 documentos que são aplicáveis a depender do contrato:

- Decreto Nº 10.278, de 18/03/2020
- Decreto-Lei Nº 5.452, de 01/05/1943
- Emenda Constitucional nº 115, de 10/02/2022
- IN GSI Nº 05, de 30/08/2021
- Instrução Técnica CBMRN Nº 16, de 2022
- Instrução Técnica CBMRN Nº 21, de 2022
- Lei Complementar (RN) Nº 601, de 07/08/2017
- Lei Nº 12.682, de 09/07/2012
- Lei Nº 12.846, de 01/08/2013
- Lei Nº 12.965, de 23/04/2014
- Lei Nº 13.709, de 14/08/2018
- Lei Nº 13.853, de 08/07/2019
- Lei Nº 13.874, de 20/09/2019
- Lei Nº 14.063, de 23/09/2020
- Lei Nº 8.078, de 11/09/1990
- Lei Nº 9.296, de 24/07/1996
- Lei Nº 9.472, de 16/07/1997
- Lei Nº 9.609, de 19/02/1998
- Lei Nº 9.610, de 19/02/1998
- NBR 15219, de 16/04/2020
- NBR 5419-1, de 22/05/2015
- NBR 5419-2, de 22/05/2015
- NBR 5419-4, de 22/05/2015
- Resolução ANATEL Nº 738, de 21/12/2020
- Resolução ANATEL Nº 740, de 21/12/2020
- Resolução ANATEL nº 746, de 22/06/2021
- Resolução CD/ANPD Nº 1, de 28/10/2021
- Resolução CD/ANPD Nº 4, de 24/02/2023
- IN GSI Nº 06, de 23/12/2021
- ISO/IEC 17788, de 07/12/2015
- ISO/IEC 20889, de 2018
- Lei Nº 12.737, de 30/11/2012
- NBR 11515, de 10/12/2007

Orientativo

Orientativo

Orientativo

Orientativo

Orientativo

- NBR 16167, de 18/12/2020	Orientativo
- NBR 16337, de 15/04/2020	Orientativo
- NBR ISO 10015, de 01/07/2020	Orientativo
- NBR ISO 10018, de 09/02/2022	Orientativo
- NBR ISO 19011, de 20/12/2018	Orientativo
- NBR ISO 30301, de 26/10/2016	Orientativo
- NBR ISO 31000, de 28/03/2018	Orientativo
- NBR ISO 31073, de 14/07/2022	Orientativo
- NBR ISO/IEC 27003, de 24/04/2020	Orientativo
- NBR ISO/IEC 27004, de 29/08/2017	Orientativo
- NBR ISO/IEC 27005, de 24/10/2019	Orientativo
- NBR ISO/IEC 27007, de 11/05/2021	Orientativo
- NBR ISO/IEC 27032, de 09/06/2015	Orientativo
- NBR ISO/IEC 27035-3, de 15/07/2021	Orientativo
- NBR ISO/IEC 27037, de 09/12/2013	Orientativo
- NBR ISO/IEC 27555, de 16/02/2023	Orientativo
- NBR ISO/IEC 29100, de 27/03/2020	Orientativo
- NBR ISO/IEC 29134, de 26/11/2020	Orientativo
- NBR ISO/IEC 29151, de 26/11/2020	Orientativo
- NBR ISO/IEC 29184, de 25/06/2021	Orientativo
- NBR ISO/IEC 38505-1, de 20/01/2020	Orientativo
- NBR ISO/IEC 38505-2, de 12/07/2022	Orientativo
- Portaria GSI/PR N° 93, de 18/10/2021	Orientativo